NETWORKWALKS

Cybersecurity Internship - Batch B083

Penetration Testing Report

Mediroza General Hospital

CLIENT	Mediroza General Hospital
TARGET	https://medirozahospital.com
TYPE	Black-box Penetration Test & Vulnerability Assessment
DURATION	5 Days
PREPARED BY	Ihtisham Khan
REPORT DATE	05 October 2026

Classification: CONFIDENTIAL - Authorized training environment

This report documents only the tester-captured and source-supported findings included in the evidence set.

Document Control and Engagement Context

This report documents the Week 4 black-box penetration testing and vulnerability assessment conducted against the Mediroza General Hospital training environment. The project brief identifies the target as https://medirozahospital.com, states that written authorization has been granted, and limits testing to the target domain. Social engineering, denial-of-service activity, and testing outside the agreed scope were excluded.

Client	Mediroza General Hospital
Engagement	Penetration Testing & Vulnerability Assessment
Testing model	Black-box
Target	https://medirozahospital.com
Duration	5 days
Authorization	Written authorization granted in project brief
Restrictions	Target domain only; no social engineering; no denial of service; no out-of-scope testing
Prepared by	Ihtisham Khan
Report date	05 October 2026
Classification	Confidential - Authorized educational assessment

Evidence basis: The findings below are based on the supplied Week 4 project material and the tester-captured screenshots provided for this report. Results that were not demonstrated by the supplied evidence have not been presented as confirmed findings.

Table of Contents

Document Control and Engagement Context 2

1. Executive Summary 4

1.1 Attack Chain Overview . . . 4

2. Scope, Rules of Engagement and Methodology 6

2.1 Scope and Rules of Engagement . . . 6

2.2 Testing Environment and Tools . . . 6

2.3 Methodology . . . 6

2.4 Limitations . . . 6

3. Milestone 1 - Initial Access 7

3.1 Reconnaissance and Exposed Paths . . . 7

3.2 Authentication Testing . . . 8

4. Milestone 2 - Protected PDF Analysis and Recovery 11

4.1 Encryption and Hash Extraction . . . 11

5. Milestone 3 - Critical Data Exposure 13

5.1 Readable Summary - Staff Salaries . . . 15

5.2 Readable Summary - Shareholder Details . . . 16

6. Risk Assessment and Remediation Plan 17

6.1 Risk Rating Summary . . . 17

6.2 Prioritized Remediation Plan . . . 17

6.3 Recommended Verification after Remediation . . . 17

7. Conclusion 18

1. Executive Summary

The assessment identified a chained compromise path that progressed from information disclosure and weak application controls to unauthorized access to confidential patient documents and, ultimately, exposure of an old database backup containing staff salary and shareholder information. The overall security posture observed during this engagement is rated Critical because multiple weaknesses could be combined to produce broad confidentiality impact.

Seven confirmed findings are documented in this report: three Critical, two High, and two Medium. The most serious issues were SQL injection in the patient authentication workflow, public exposure of an old database backup, and disclosure of confidential staff and shareholder records.

ID	Finding	Risk
F-01	Public directory listing under /patient/	**Medium**
F-02	SQL injection in patient portal authentication	**Critical**
F-03	Unauthorized access to confidential patient reports	**High**
F-04	Weak password protection on patient PDF files	**High**
F-05	Sensitive internal information stored in PDF metadata	**Medium**
F-06	Public /old/ directory and exposed database backup	**Critical**
F-07	Confidential staff salary and shareholder data exposed in plain text	**Critical**

Overall Risk: Critical. Immediate remediation should focus on the patient portal SQL injection, public backup exposure, access control for patient reports, and removal of sensitive data from web-accessible locations.

1.1 Attack Chain Overview

The assessment demonstrated how individually different weaknesses could be combined. The diagram below summarizes the validated path from reconnaissance to sensitive data exposure.

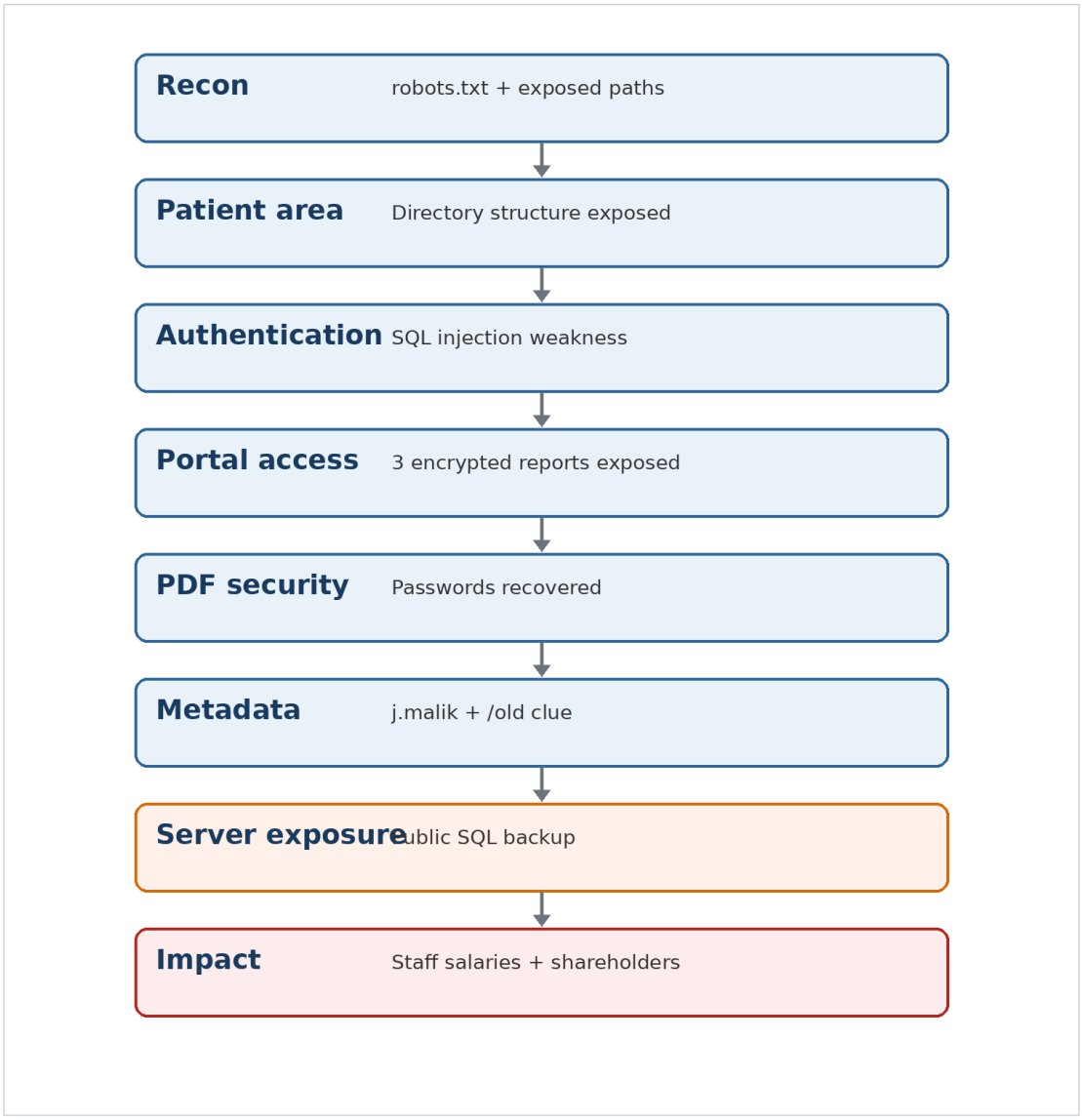


Figure 1. Validated attack chain observed during the assessment.

2. Scope, Rules of Engagement and Methodology

2.1 Scope and Rules of Engagement

The engagement was defined as a five-day black-box penetration test of the Mediroza General Hospital web environment. Testing was limited to the target domain. The project rules prohibited social engineering, denial-of-service testing and activity outside the agreed scope.

2.2 Testing Environment and Tools

Testing was carried out from Kali Linux in a controlled internship environment. Tools observed in the evidence set included:

• Reconnaissance: curl, WHOIS, DNS lookup, Nmap, WhatWeb and wafw00f.

• Web application assessment: browser-based testing and Burp Suite Community Edition.

• PDF analysis and password recovery: NetworkWalks Hash Calculator/Password Cracker, pdf2john, John the Ripper, pdfcrack and qpdf.

• Metadata analysis: ExifTool.

• Data review: direct inspection of the exposed SQL backup and conversion of relevant rows into readable summary tables.

2.3 Methodology

The work followed a staged workflow consistent with the project milestones: reconnaissance and attack-surface discovery; authentication testing; controlled exploitation of the identified weakness; retrieval and assessment of protected documents; metadata analysis; follow-up investigation of the server-side clue; and documentation of the resulting confidential data exposure.

2.4 Limitations

No source-code review was performed. The assessment was black-box and evidence-driven. No social engineering or denial-of-service testing was performed, and the report does not claim findings that were not supported by the supplied screenshots or project material.

3. Milestone 1 - Initial Access

Milestone 1 required the identification of a weakness in the web application, proof of restricted-area access, and retrieval of three confidential patient PDF reports. The following findings document that path.

3.1 Reconnaissance and Exposed Paths

Reconnaissance identified a robots.txt file containing disallowed paths. The entries exposed the existence of /patient/, /staff/ and /old/. The /patient/ path was selected for further assessment, while /old/ later became important during Milestone 3.



Figure 2. robots.txt disclosed the /patient/, /staff/ and /old/ paths.

F-01 - Public Directory Listing under /patient/ — MEDIUM

Affected component: https://medirozahospital.com/patient/

Description: Browsing to the patient directory exposed an index listing rather than denying directory access or serving only the intended application page. The listing revealed internal application files and folders, including reports, download.php, error_log, login.php, logout.php and portal.php.

Security impact: Directory indexing exposes application structure and useful internal filenames. While it did not by itself provide full compromise, it reduced the effort required to identify authentication and report-delivery components.

Risk rationale: Rated Medium because the issue is primarily information disclosure but materially assists further exploitation.

Recommendation: Disable directory indexing for web-accessible directories, provide explicit index handlers, and review the web root for files that should not be publicly discoverable.

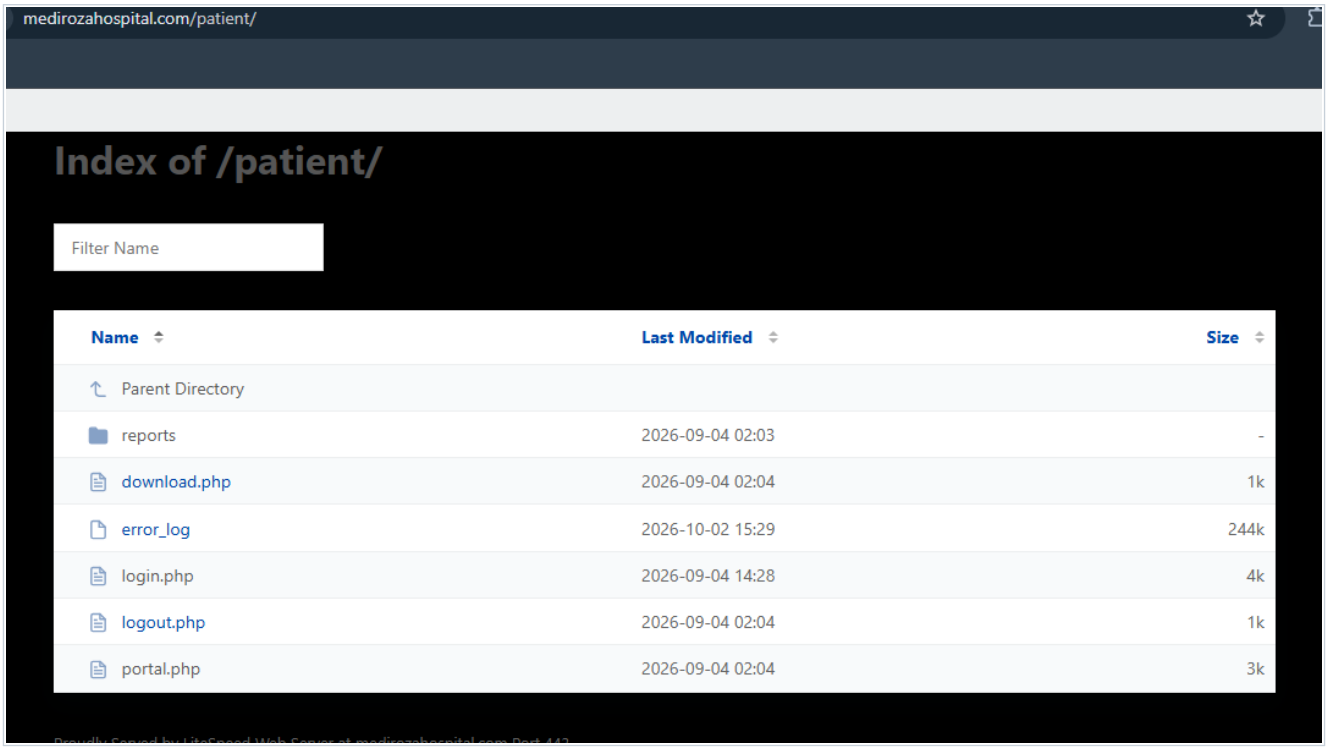


Figure 3. Directory indexing under /patient/ exposed application files and the reports folder.

3.2 Authentication Testing

F-02 - SQL Injection in Patient Portal Authentication — CRITICAL

Affected component: /patient/login.php

Description: Testing the username input caused the application to return a raw MySQL syntax error. This behavior demonstrated that user-controlled input was reaching a database query without sufficient parameterization or safe handling.

Evidence: The login page displayed a mysqli_query() SQL syntax error after crafted input was supplied. Subsequent testing resulted in access to the restricted patient portal without valid credentials.

Security impact: Successful exploitation bypassed the authentication boundary and exposed confidential patient reports. Because the weakness directly defeated access control, the finding is considered Critical.

Recommendation: Replace dynamically constructed SQL statements with parameterized queries or prepared statements. Apply server-side input validation, use least-privileged database accounts, and suppress database error details from client-facing responses.

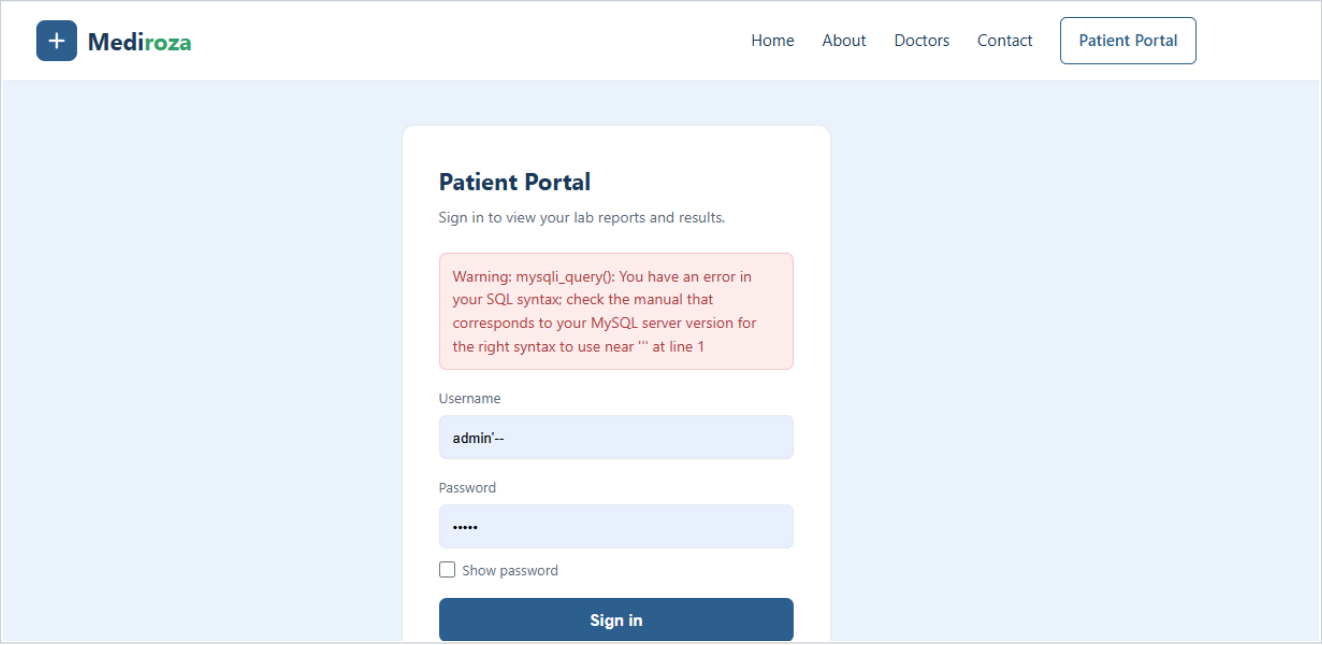


Figure 4. The patient login returned a raw MySQL syntax error during crafted-input testing.

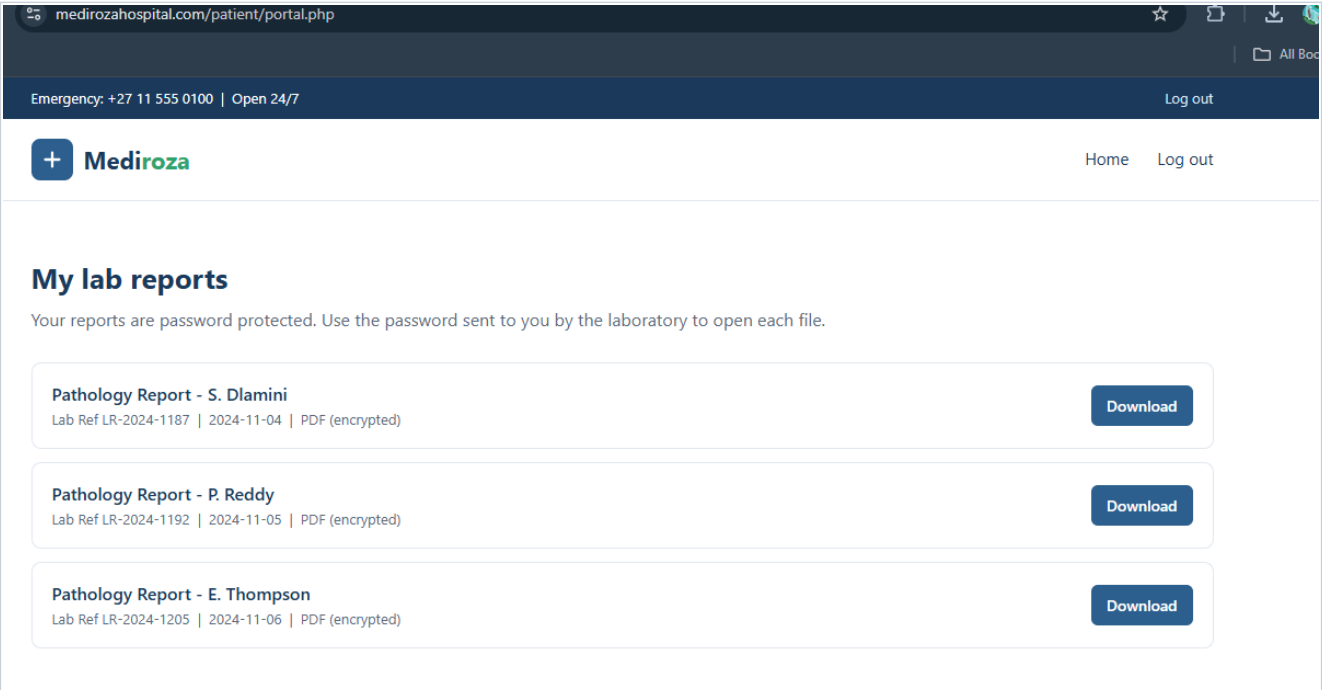


Figure 5. Restricted patient portal reached after authentication bypass; three encrypted pathology reports were visible.

F-03 - Unauthorized Access to Confidential Patient Reports

HIGH

Affected component: /patient/portal.php and report download functionality

Description: Once the authentication boundary was bypassed, the portal exposed three encrypted pathology reports. The reports belonged to Sipho Dlamini, Priya Reddy and Emily Thompson and could be downloaded from the portal.

Security impact: The issue resulted in unauthorized disclosure of confidential health information. Encryption on the PDF files reduced immediate readability but did not prevent retrieval, and the passwords were subsequently recovered during Milestone 2.

Recommendation: Enforce server-side authorization on every report request and download, store sensitive documents outside the public web root, bind documents to the authenticated user, and

perform authorization checks independent of page navigation state.

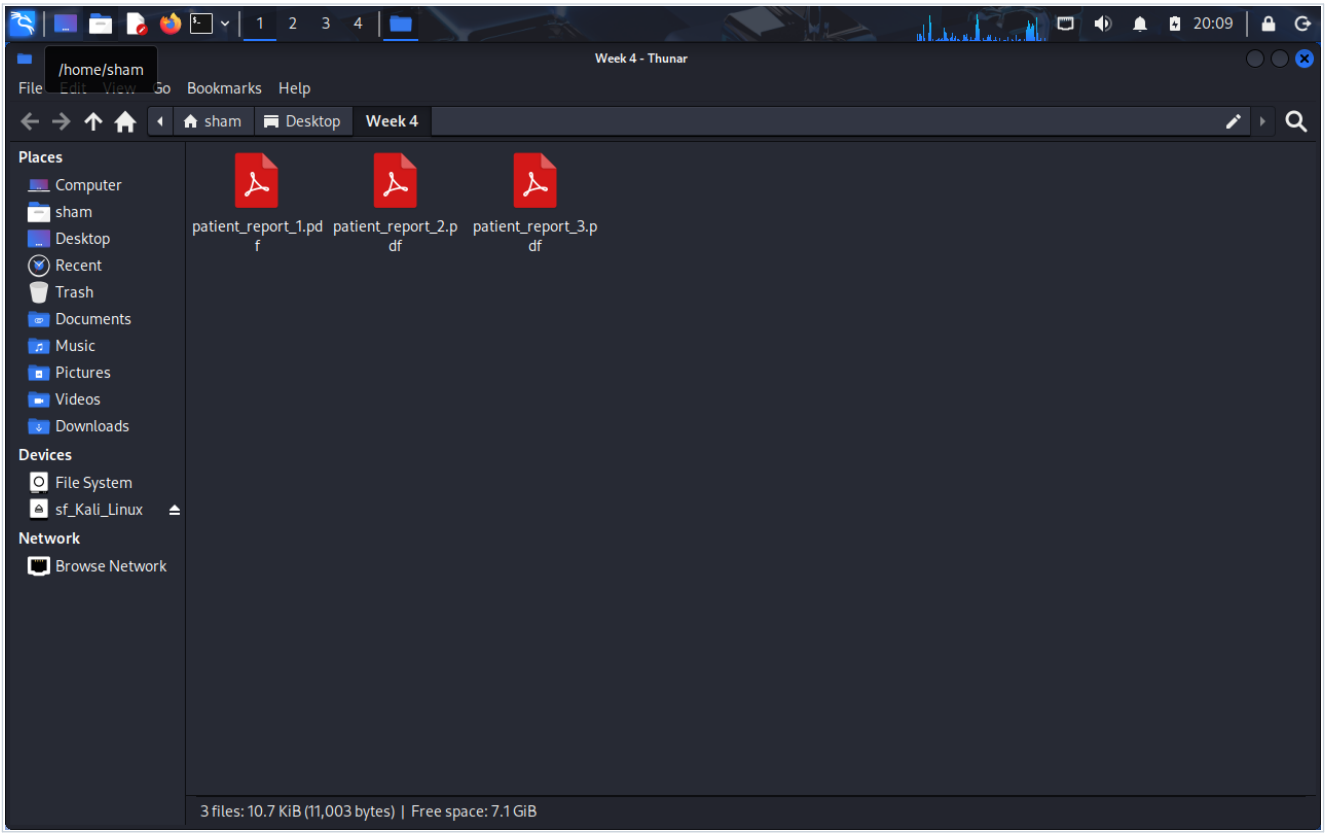


Figure 6. All three protected patient PDF files were successfully retrieved to the testing workstation.

4. Milestone 2 - Protected PDF Analysis and Recovery

The three retrieved patient documents were password protected. The objective of Milestone 2 was to analyze the protection, recover access to all three files, and verify successful decryption.

4.1 Encryption and Hash Extraction

The protected PDFs were identified as encrypted files and their password-verification material was extracted for controlled dictionary-based testing. The evidence below shows a PDF hash extracted in a format compatible with common password-auditing tools.



Figure 7. Hash Calculator identified the document as encrypted and extracted a crackable PDF hash.

F-04 - Weak Password Protection on Patient PDF Files

HIGH

Affected component: patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf

Description: All three report passwords were recoverable using dictionary/wordlist-based testing. Two passwords were extremely common values and the third was also present in a standard wordlist used during the lab.

Security impact: An attacker who obtains the protected files can recover the passwords quickly enough that PDF-level password protection cannot be treated as an effective security boundary for confidential health information.

Risk rationale: Rated High because the weakness directly undermines confidentiality of the retrieved patient documents, although file retrieval was first required.

Recommendation: Use strong, unique passphrases if document encryption is required, avoid common passwords and dictionary terms, and rely primarily on robust application-level access controls rather than document passwords.

File	Recovered password
patient_report_1.pdf	123456
patient_report_2.pdf	password
patient_report_3.pdf	!@#$%^&

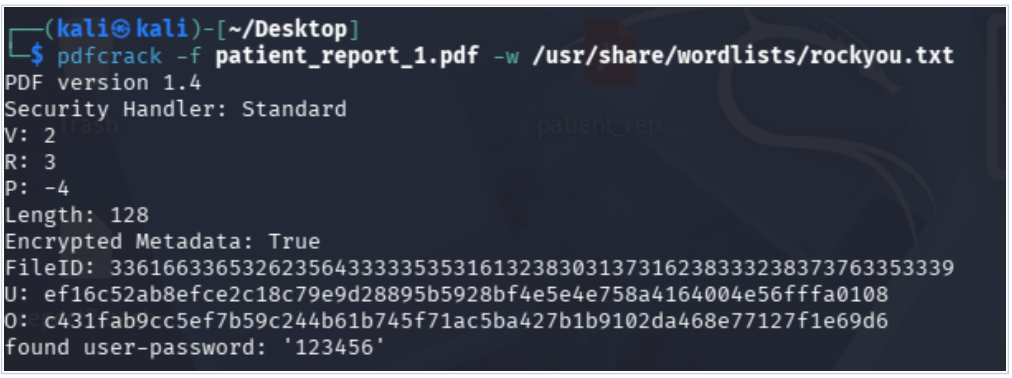


Figure 8. Local password-auditing result for patient report 1: password recovered as 123456.

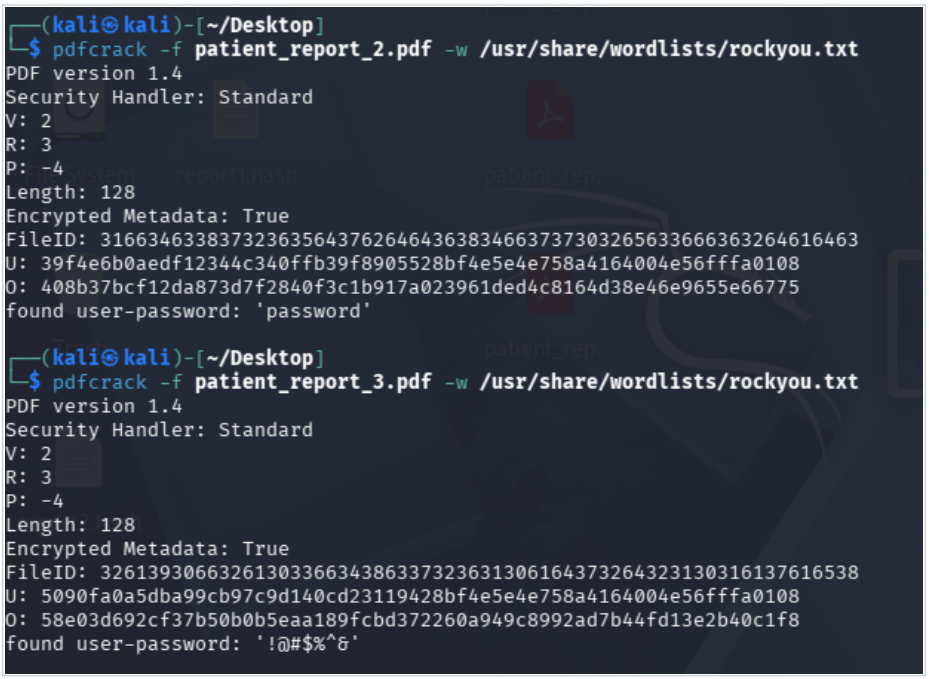


Figure 9. Local password-auditing results for patient reports 2 and 3: passwords recovered as password and !@#$%^&.

Each recovered password was validated by opening the corresponding report. Full report screenshots are included in Appendix A.

5. Milestone 3 - Critical Data Exposure

Milestone 3 required deeper analysis of the material recovered during the earlier stages. The decisive clue was stored in PDF metadata and connected the patient-report exposure to a publicly accessible server backup.

F-05 - Sensitive Internal Information Stored in PDF Metadata

MEDIUM

Affected component: Decrypted patient report 3

Description: ExifTool analysis of the decrypted third patient report exposed internal metadata that should not have been present in a distributed clinical document.

Evidence: The Author field was j.malik and the Comments field stated: DB backup moved to /old before site migration, do not delete. This directly identified the /old location as a potential backup path.

Security impact: The metadata disclosed an internal username and an operational note that materially advanced the assessment to a more serious server-side exposure.

Recommendation: Sanitize metadata before patient files are published or distributed. Remove internal usernames, comments, paths, system notes and application-specific metadata as part of the document-generation process.

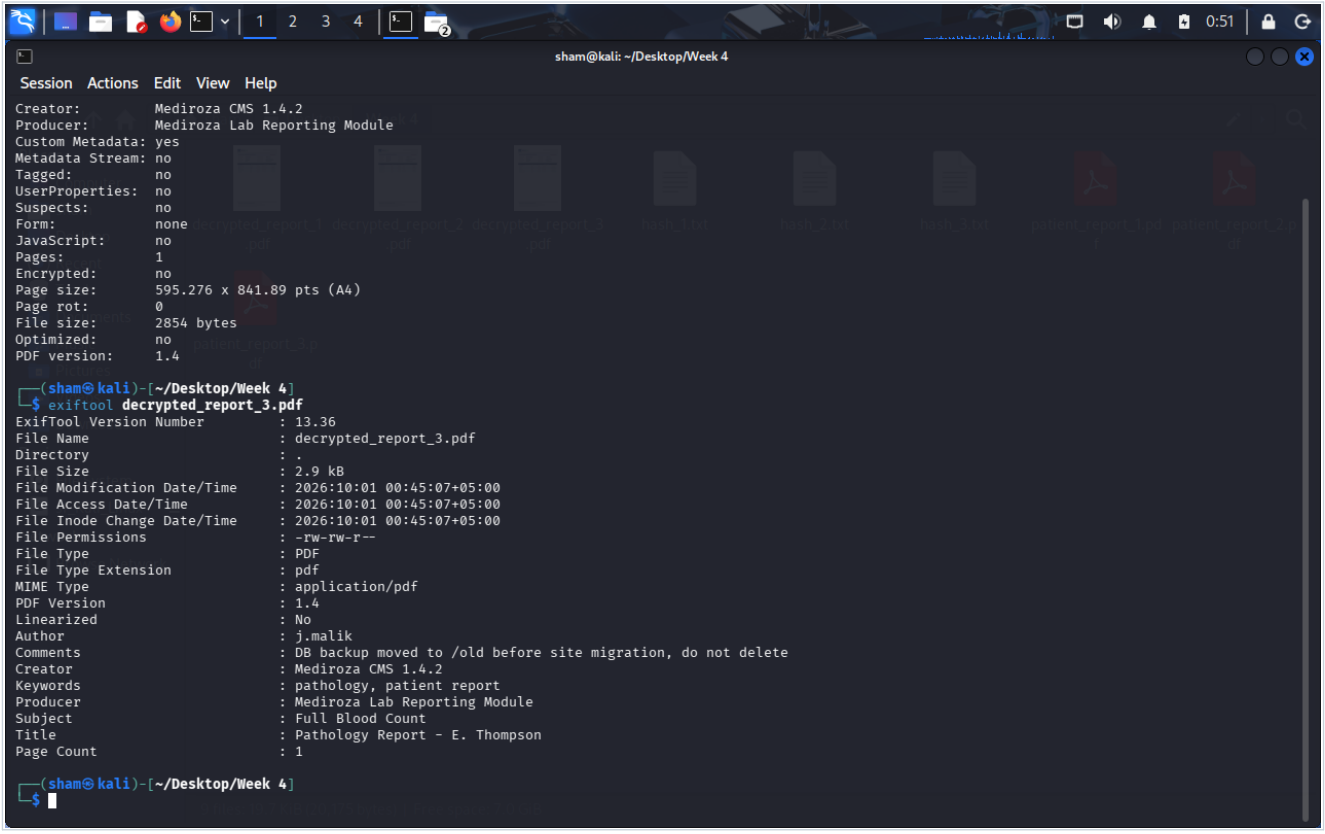


Figure 10. ExifTool revealed author j.malik and a comment pointing to the /old backup location.

F-06 - Public /old/ Directory and Exposed Database Backup

CRITICAL

Affected component: https://medirozahospital.com/old/

Description: The /old/ path was publicly browsable and directory listing was enabled. The directory exposed a database backup named mediroza_db_backup_2019.sql.

Evidence: The backup could be accessed from the public web server. Its header explicitly identified it as an internal Mediroza General Hospital database backup and warned that it contained confidential staff and shareholder records.

Security impact: Exposure of a database backup bypasses normal application controls and can disclose large volumes of historical or confidential data in a single file. This represents a direct and severe confidentiality failure.

Recommendation: Remove database backups from all public web directories immediately, disable directory indexing, store backups in protected non-web storage, enforce access controls, encrypt sensitive backups, and audit the server for additional historical copies.

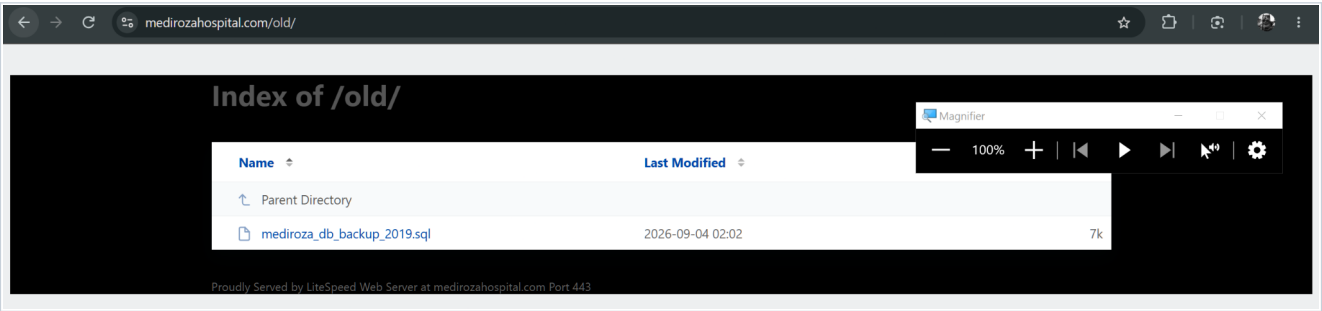


Figure 11. Directory listing under /old/ exposed mediroza_db_backup_2019.sql.

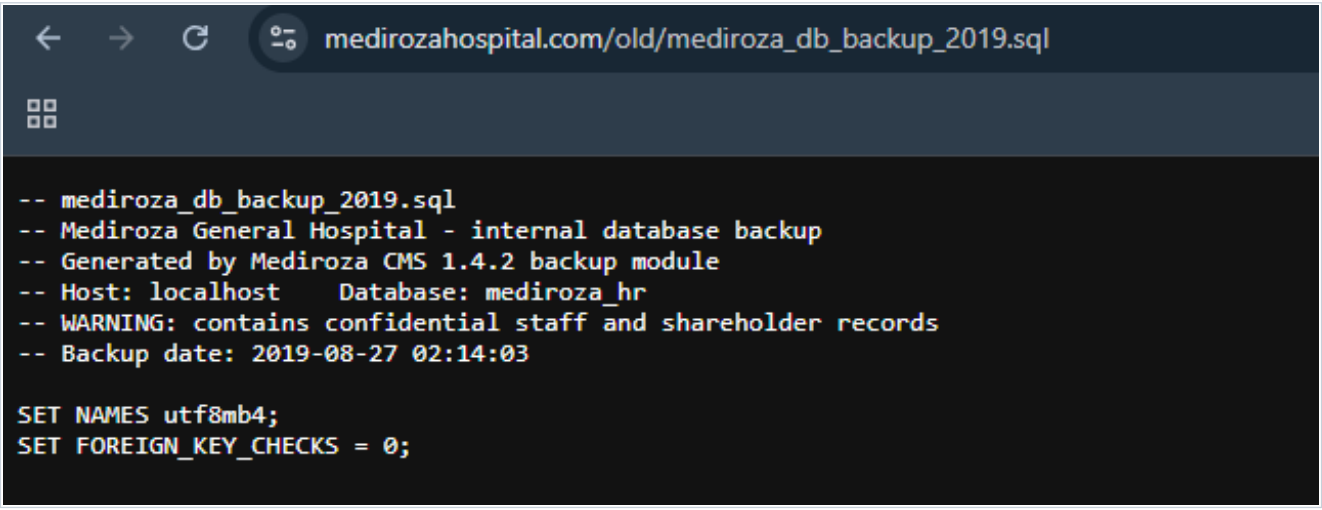


Figure 12. The exposed SQL backup identified itself as an internal backup containing confidential staff and shareholder records.

F-07 - Confidential Staff Salary and Shareholder Data Exposed in Plain Text

CRITICAL

Affected component: mediroza_db_backup_2019.sql

Description: Inspection of the exposed backup showed a staff table containing employee identity, role, department, contact fields, national identifiers, salary and employment dates, as well as a shareholder table containing ownership percentages, share counts and share classes.

Security impact: The backup exposed sensitive personnel and financial ownership information at scale. The information could support privacy violations, fraud, targeted social engineering and other secondary abuse if accessed outside the controlled lab.

Risk rationale: Rated Critical because a single publicly accessible file exposed broad confidential datasets without authentication.

Recommendation: Remove the public backup, rotate any credentials or secrets if present, notify appropriate internal stakeholders, perform a full exposure review, restrict backups to dedicated

protected storage, encrypt backups at rest and implement retention/deletion controls.

```
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099080',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','8501112313208 3',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198080',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O''Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297080',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;
```

Figure 13. Plain-text staff rows exposed names, roles, departments and monthly salary values alongside additional personal fields.

5.1 Readable Summary - Staff Salaries

For reporting clarity, only the fields required by the project task are reproduced below. Additional personal fields present in the backup are intentionally not repeated in this summary.

Employee	Job title	Department	Monthly salary (ZAR)
Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	138,000
Sarah Botha	Chief Financial Officer	Finance	152,000
Dr. Johan van der Merwe	Medical Director	Management	160,000
Dr. Anita Naicker	Consultant Cardiologist	Cardiology	132,000
Dr. Ahmed Kara	Consultant Physician	Internal Medicine	128,000
Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	74,000
Michael Roberts	HR Director	Human Resources	96,000
Susan Pretorius	HR Officer	Human Resources	32,000
Jameel Malik	IT Systems Administrator	IT	58,000
Thabo Molefe	Network Engineer	IT	46,000
Nomvula Khumalo	Registered Nurse	Emergency & Trauma	34,000
Lerato Mokoena	Registered Nurse	Paediatrics	33,000
Bongani Ndlovu	Registered Nurse	Cardiology	35,000
Zanele Mahlangu	Nursing Sister	Theatre	42,000
Kagiso Sithole	Pharmacist	Pharmacy	61,000
Naledi Zulu	Pharmacy Assistant	Pharmacy	26,000
Themba Nkosi	Radiographer	Radiology	44,000
Palesa Radebe	Radiographer	Radiology	43,000
Deepak Pillay	Lab Technologist	Diagnostics Lab	41,000

Employee	Job title	Department	Monthly salary (ZAR)
Kavitha Govender	Lab Technician	Diagnostics Lab	35,000
Dr. Suresh Moodley	Consultant Radiologist	Radiology	130,000
Dr. Fatima Patel	Paediatrician	Paediatrics	118,000
Nisha Singh	Physiotherapist	Rehabilitation	48,000
Dr. Vikram Chetty	Anaesthetist	Theatre	135,000
David Smith	Facilities Manager	Operations	52,000
Karen O'Connor	Billing Administrator	Finance	29,000
James Wilson	Security Supervisor	Operations	27,000
Linda Fourie	Receptionist	Front Office	19,000
Peter van Wyk	Procurement Officer	Supply Chain	38,000
Andile Mbeki	Ward Clerk	Administration	21,000

The metadata author value j.malik correlates with Jameel Malik, listed in the staff table as an IT Systems Administrator. This provides a direct link between the PDF metadata clue and the exposed backup path.

```
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO_INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Figure 14. Plain-text shareholder rows exposed ownership percentages, share counts and share classes.

5.2 Readable Summary - Shareholder Details

Shareholder	Ownership	Shares held	Share class
Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
Dr. Johan van der Merwe	12.0%	120,000	Ordinary
Reddy Family Trust	11.0%	110,000	Ordinary
Thabo Molefe	10.0%	100,000	Ordinary
Sarah Botha	9.0%	90,000	Ordinary
Dr. Ahmed Kara	8.0%	80,000	Preferential
Naledi Zulu	7.0%	70,000	Ordinary
Michael Roberts	6.0%	60,000	Ordinary
Dr. Vikram Chetty	4.0%	40,000	Preferential

6. Risk Assessment and Remediation Plan

6.1 Risk Rating Summary

Risk ratings use the project-required qualitative scale of Critical, High, Medium and Low. Ratings in this report reflect the observed impact and exploitability within the authorized assessment.

ID	Finding	Risk	Justification
F-01	Public directory listing under /patient/	Medium	Application structure disclosure and attack-surface reduction.
F-02	SQL injection in patient portal authentication	Critical	Direct authentication bypass and access-control failure.
F-03	Unauthorized access to patient reports	High	Confidential health documents retrievable without valid authorization.
F-04	Weak PDF passwords	High	Document confidentiality defeated with wordlist-based recovery.
F-05	Sensitive PDF metadata	Medium	Internal username and backup-location clue disclosed.
F-06	Public /old/ backup exposure	Critical	Unauthenticated access to internal database backup.
F-07	Staff and shareholder data exposure	Critical	Large-scale confidential personnel and ownership data exposed in plain text.

6.2 Prioritized Remediation Plan

Priority	Finding	Action
Immediate	F-02	Replace vulnerable SQL construction with prepared statements; suppress database errors; retest all authentication inputs.
Immediate	F-06 / F-07	Remove /old/ and all database backups from public web paths; disable directory listing; review server for additional copies.
Immediate	F-03	Enforce server-side authorization on portal and download requests; store patient reports outside public web root.
Short term	F-04	Adopt strong unique passphrases where document encryption is required; do not rely on PDF passwords as primary access control.
Short term	F-05	Strip internal PDF metadata and operational comments before distribution.
Short term	F-01	Disable directory indexing across web-accessible directories and review exposed files/folders.
Medium term	All	Introduce routine secure configuration review, authenticated access testing, backup-location audits and regression testing after remediation.

6.3 Recommended Verification after Remediation

• Confirm malformed and crafted login input no longer produces database errors or bypasses authentication.

• Verify direct access to /patient/, /old/ and report-download endpoints is denied unless specifically authorized.

• Search the web root and historical deployment directories for database backups, logs and staging files.

• Re-test patient report access using accounts with different authorization levels.

• Regenerate sample reports and verify that internal metadata, comments and usernames are absent.

• Validate revised password requirements and confirm that document protection is supplementary to application access control.

7. Conclusion

The assessment demonstrated a complete compromise chain beginning with information disclosure and progressing through SQL injection, unauthorized portal access, recovery of protected patient reports, metadata leakage, public backup exposure and disclosure of confidential staff and shareholder information.

The most urgent remediation items are the SQL injection vulnerability, removal of the exposed database backup, and enforcement of server-side authorization around patient documents. Because multiple weaknesses combined to expose both medical and internal business data, the overall security risk for the tested environment is assessed as Critical.

After remediation, a focused re-test should be performed to verify that the authentication workflow, file-access controls, directory configuration, backup handling and document-generation process no longer reproduce the findings documented in this report.

Appendix A - Proof of Successful PDF Access

The screenshots below demonstrate that the recovered passwords were valid and the three protected pathology reports could be opened successfully. These images are included as supporting evidence and are not repeated in the main findings narrative.



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name:	**Sipho Dlamini**	Report Date:	**2024-11-04**
Patient ID:	**MG-P-10231**	Referring Dr:	**Dr. Anita Naicker**
Date of Birth:	**1984-06-12**	Specimen:	**Whole blood (EDTA)**
Gender:	**Male**	Lab Ref No:	**LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10^9/L	4.0 - 11.0	HIGH
Platelet Count	245	x10^9/L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Figure 15. Successfully opened pathology report for Sipho Dlamini.

Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:	**Priya Reddy**	Report Date:	**2024-11-05**
Patient ID:	**MG-P-10244**	Referring Dr:	**Dr. Johan van der Merwe**
Date of Birth:	**1991-02-28**	Specimen:	**Serum**
Gender:	**Female**	Lab Ref No:	**LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Figure 16. Successfully opened pathology report for Priya Reddy.



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT CONFIDENTIAL

Patient Name:	**Emily Thompson**	Report Date:	**2024-11-06**
Patient ID:	**MG-P-10258**	Referring Dr:	**Dr. Ahmed Kara**
Date of Birth:	**1978-09-03**	Specimen:	**Serum**
Gender:	**Female**	Lab Ref No:	**LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2

Figure 17. Successfully opened pathology report for Emily Thompson.

Appendix B - Reference Materials

1.	NetworkWalks, “Penetration Testing Project - Mediroza General Hospital,” Batch B083, Week 4.
2.	NetworkWalks, “Mediroza General Hospital - Pentest Project Solution,” Week 4 reference solution.
3.	Tester-captured screenshots supplied for this report, covering reconnaissance, web application testing, PDF password recovery, metadata analysis and database exposure.

Note: The solution document was used only as a reference for the intended lab workflow. Confirmed findings and evidence in this report are based on the supplied project material and the tester-captured screenshots.